

Security Governance - Notes

CHAPTER 1: Introduction

The Enterprise as a Complex System

Every organization exists to fulfil a **mission**, that is, the fundamental business objective that justifies its existence and defines what it delivers to the world. An energy provider exists to produce and sell energy to its customers; a manufacturer exists to produce and distribute goods; a bank exists to safeguard and move money. This mission is the anchor from which every other organizational choice descends, because once the objective is fixed, the enterprise must structure itself in a way that allows that objective to be reached reliably and repeatably.

From the outside, an enterprise can be understood as a kind of black box: it consumes inputs and produces goods or services that are offered to customers. Inside that black box, however, sits a highly structured machine composed of three interlocking ingredients. The first ingredient is **people** — the employees whose work actually moves the organization toward its objective. The second is **processes** — the structured sequences of activity through which work is carried out, formalized under the discipline of Business Process Management (BPM), in which people and technology transform inputs into outputs. The third is the **digital infrastructure** — the technological substrate of servers, networks, applications and data on which the people rely to perform their processes. The way these three are arranged depends heavily on scale: a small company tends to have a flat structure with few intermediaries, whereas a large enterprise develops a deep hierarchy with many layers of coordination.

This composition is precisely what makes the enterprise a **complex system**, and it is also the source of its first and most persistent vulnerability. Because the digital infrastructure is operated by human beings, the point of contact between people and technology becomes the weakest link in the whole arrangement. Managing the security of even a small company is therefore never a trivial task, and the difficulty grows sharply with organizational size and complexity.

The Concept of Governance

Among the many processes an enterprise runs, this treatment concentrates on **governance**. Governance, in its broadest sense, is the totality of the processes of

governing — whether these are undertaken by a government, a market, or a network, and whether they act over a family, a tribe, a formal or informal organization, a territory, or across territories. Governance operates through the laws, norms, power, and language of an organized society. Expressed in operational terms, governance is the set of processes of interaction and decision-making among the actors involved in a collective problem, and these processes lead to the creation, reinforcement, or reproduction of social norms and institutions.

Two words distill the essence of this definition and should be held firmly in mind: **processes** and **norms**. To govern is to look at the business objective and to put in place everything necessary to reach it, which means identifying the processes required and then operating those processes so that the objective is achieved *in compliance with the surrounding environment*. Doing governance therefore always carries a double burden. It is not enough to design processes from a purely functional point of view, asking only whether they work; one must simultaneously keep the **compliance** dimension in view, ensuring that the processes respect the applicable norms. Those norms may be external laws, internal company rules, contractual obligations, or regulatory prescriptions. Governance without compliance is incomplete governance.

Enterprise, Corporate, and Business Governance

The most general form of this discipline is **enterprise governance**, which concerns how to govern the company as a whole. Formally, enterprise governance is the structure and the set of relationships that control, direct, or regulate the performance of an enterprise together with its projects, portfolios, infrastructure, and processes. In other words, it is the exercise of identifying the processes necessary to control the company itself. Enterprise governance is conventionally split into two complementary halves.

The first half is **corporate governance**, understood as the system of rules, practices, and processes by which a firm is directed and controlled. Corporate governance is essentially concerned with **compliance processes**: it is a general, mission-independent approach that guarantees the firm is being run in a controlled and accountable way, and it applies to any company regardless of what that company actually produces.

The second half is **business governance**, understood as the set of policies and business processes that determine the way the organization's business is actually run. Business governance is concerned with **performance processes**, and unlike

corporate governance it is highly specific to the mission. Where corporate governance asks whether the firm is being directed and controlled properly in a generic sense, business governance asks whether the firm is performing well against its particular objective. The two are therefore distinguished cleanly: corporate governance is general and compliance-oriented, business governance is specific and performance-oriented.

The Hierarchical Structure and the Direct/Control Loop

An enterprise is typically organized as a **pyramid**. At the apex sit a small number of people who make broad, high-consequence decisions; those decisions then propagate downward through the structure, becoming progressively more concrete at each descent. This vertical arrangement gives rise to three well-known management levels, and the mechanics of corporate governance can be read directly off them.

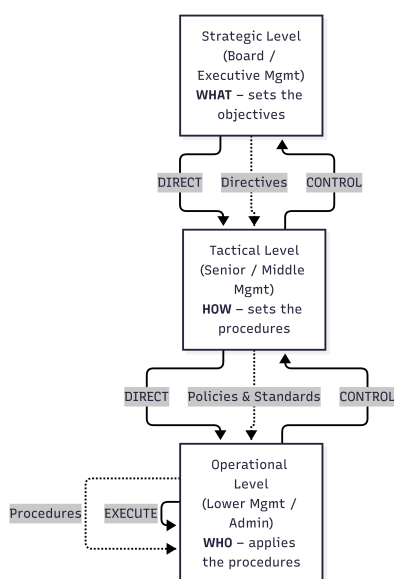
At the **strategic level** — populated by the Board of Directors and executive management — decisions about cybersecurity are taken at their most abstract. Directors formalize these decisions into **Directives**, documents that state the strategic objectives of the company. A directive at this altitude might declare that the infrastructure must be protected from external attackers, but it deliberately refrains from specifying *how* this is to be accomplished. The strategic level owns the **WHAT**: it sets the objectives.

At the **tactical level** — populated by senior and middle management — the mandate received from above is translated into more concrete objectives. Here the discussion turns to *how things should be done*, and the abstract goal begins to acquire shape. It is at this layer that one starts to identify the procedures needed to protect the assets, defining the **policies** and the **company standards** that will govern behaviour. These standards are not necessarily imposed from outside by bodies such as ISO; they are frequently the internal standards the company chooses to adopt for itself. The tactical level remains a *meta* layer, in the sense that it defines the way things must be done without yet touching the machines. The tactical level owns the **HOW**: it sets the procedures.

At the **operational level** — populated by lower management and administration — the middle-level objectives are finally converted into practical reality. Here the abstract instruction to deploy, say, an identity management system becomes a concrete decision about who does exactly what, on which machine, with which

configuration. This is the layer in which people put their hands on the systems. The operational level owns the **WHO**: it applies the procedures, and it is where things are actually done.

These three levels are bound together by a continuous loop composed of three motions. **Direct** is the downward flow: it translates big, abstract objectives into concrete implementation procedures as they descend from strategic to tactical to operational. **Execute** is the practical act of doing the work at the operational level. **Control** is the upward flow: it observes whether what is being done actually works as expected, and it feeds the resulting information back up to management. When the feedback arrives at the top, management obtains a snapshot of the real situation — an understanding of how the company is genuinely behaving — and on the basis of that snapshot it can decide to hold course or to change direction, re-drafting the objectives as needed. The following diagram captures this continuous circulation.



The single most important idea to extract from this picture is that **talking about governance means talking about the implementation of a continuous loop**. Governance is not a one-off act of decision but a perpetual cycle of directing, executing, controlling, and re-directing.

Vulnerabilities as the Enemies of Governance

Once this loop is running inside a real company, it must contend with **vulnerabilities**, which are the natural enemies of the governance process. Vulnerabilities arise for two broad reasons. The first is that the technical infrastructure itself changes over time and inevitably contains bugs, errors, and even backdoors. The second, and more insidious, is the interaction between the

processes and the infrastructure — and, above all, the interaction between *people* and the infrastructure. It bears repeating as a central lesson that the most dangerous moment in the whole governance enterprise is the moment at which people come into contact with the systems.

Risk as the Governing Metric

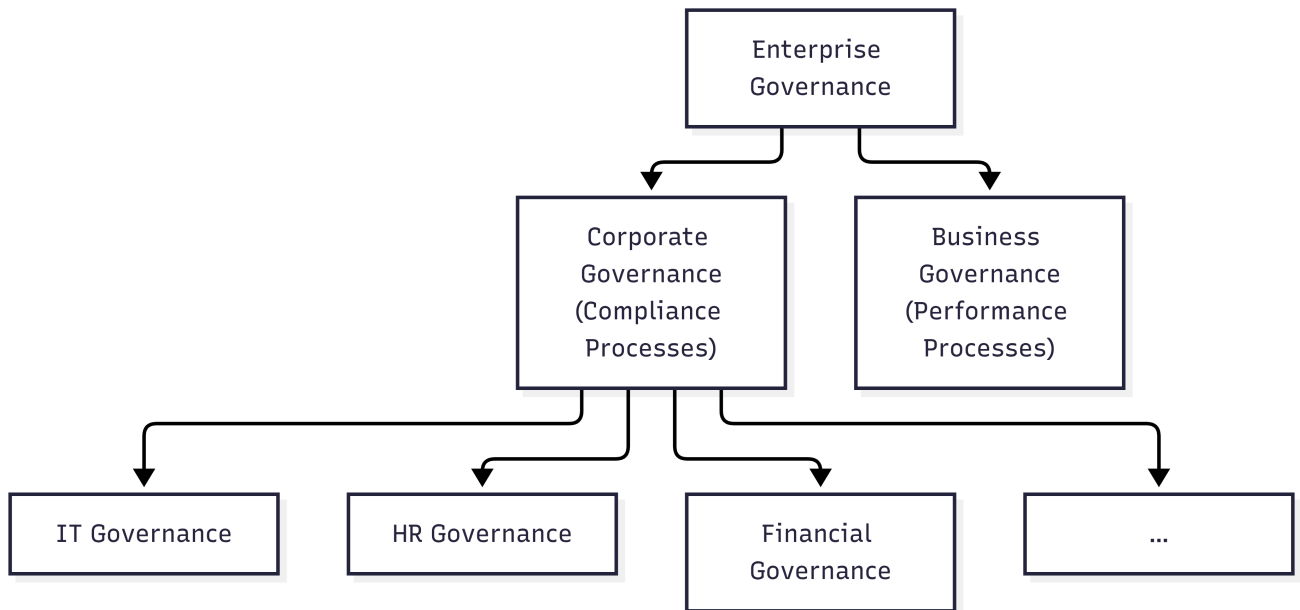
If the direct/control loop is to be steered intelligently, it must be steered against a measurable quantity. That quantity is **risk**, which may take financial, production-related, cybersecurity, or other forms. The IT Governance Institute captured this centrality when it redefined enterprise governance as the set of responsibilities and practices exercised by the board and executive management with the aim of providing strategic direction, ensuring objectives are achieved, ascertaining that risks are managed appropriately, and verifying that the enterprise's resources are used responsibly.

Once risk is accepted as the governing metric, the entire governance problem collapses into a clean **optimization process**. The direct half of the loop is charged with a single objective: reduce risk, by putting in place actions that lower the risk level. The control half of the loop is charged with the complementary objective: measure the reduction, by taking measurements, recomputing the risk, and aggregating it into a coherent picture. Governance thus becomes the continual minimization of risk under observation.

Decomposing Governance: IT Governance and Assets

Supporting business and corporate governance in practice requires more specialized sub-governances, each dedicated to a particular domain of the enterprise. Enterprise governance decomposes into corporate governance and business governance at the top, and beneath these sit the domain-specific governance sub-systems: **IT governance**, **HR governance**, **financial**

governance, and others. The following diagram shows this decomposition.



IT governance is defined as the set of processes that ensure the effective and efficient use of IT in enabling an organization to achieve its goals. It begins from the infrastructures and examines every kind of risk that arises from the digital environment, and especially the risks that arise from the *offering of services*. IT-based systems create serious risks precisely because they manage and store the majority — if not the entirety — of a company's electronic assets: the data and information stored inside the organization, the data and information transmitted across its networks, and all the systems and applications required to store, transmit, and process that data. These electronic assets are exposed to a wide range of threats aimed at compromising their three cardinal properties, **Confidentiality, Integrity, and Availability**, collectively abbreviated as **CIA**.

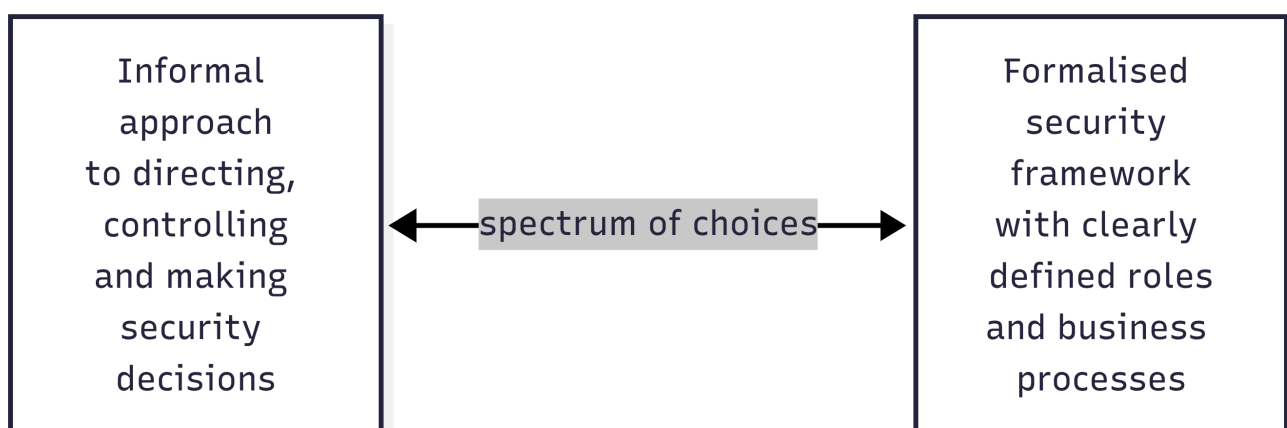
The decisive insight of IT governance is that the infrastructural view must be fused with the business view, because the two views assign radically different importance to physically identical machines. Consider a network of interconnected servers. On one server sits an archive of data; on another, identical machine sits the web server that hosts the company's online shopping site. Viewed through the infrastructure lens alone, the two servers look equivalent — both are connected, both are running, both are simply nodes in the topology. The moment the business lens is applied, the equivalence collapses. If an attacker brings down the shopping site, the company can no longer serve its customers and immediately begins to lose money, which is a serious risk. If an attacker damages the archive, the data can very often be restored from other sources, which is a comparatively minor risk. The two machines are the same; the risk they carry is not. This is why IT governance insists on considering *all* aspects of the digital world — not merely the

machines, but everything operating around them — and on first identifying which assets genuinely matter. Running a live service is an asset in the critical sense; the archive, in this example, is not an asset of the same order.

The threat landscape, moreover, is not confined to the outside. One must protect against external attackers arriving from the Internet, but one must equally guard against attackers already *inside* the organization. Employees who have become unhappy are a particularly grave danger: they know the assets intimately, they understand how the infrastructure is managed, and this superior knowledge makes them far more dangerous than an outsider who must first discover what an insider already knows.

Choosing an Approach: The Spectrum of Formalization

Having established that governance is a risk-driven control loop operating over identified assets, the practical question becomes how to implement that loop in a concrete company. There is no single universal answer — there is **no "one size fits all" approach** to security governance. Instead there is a spectrum. At one extreme lies a fully **formalized security framework**, with clearly defined roles and rigorously defined business processes. At the opposite extreme lies an **informal approach** to directing, controlling, and making security decisions. Every real company must find its proper place somewhere along this continuum.



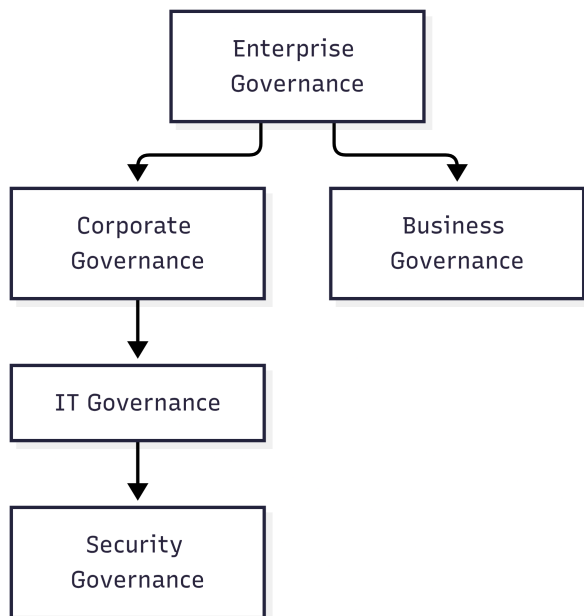
Four questions guide a company toward the right level of formalization. The first concerns **size and complexity**: how large and how complex is the organization? Small companies must lean on flexibility because they typically lack the resources for heavy formalism, while large companies will most probably require a formalized security framework simply to keep coordination tractable. The second concerns **resources**: what budget is actually available for security governance? A formalized approach is expensive — it demands certifications and sustained investment — so

a company without money cannot realistically adopt it. The third concerns **mission and the importance of security to it**: what does the organization do, and how important is security to those aims? For a bank, security is a top priority and a matter of existential dependence; for a manufacturer, security still matters but the business does not hang on the same human-facing service dependencies. The fourth concerns **external considerations**: are there contractual, legal, regulatory, or sector-specific requirements pushing the company toward a particular level of formalism? A small company might in itself prefer an informal posture, yet find itself obliged to obtain certification because it works for a public organization that demands it.

Answering these questions well requires analysing the **context**, and in practical terms the correct approach comes down to identifying three things. One must identify the **what**, meaning the security decisions to be made. One must identify the **who**, meaning the deciders who will make them. And one must identify the **data**, meaning the information required to make sensible and informed choices. These three together — decisions, deciders, and the information feeding them — constitute what is meant by a **security framework**.

Positioning and Purpose of Security Governance

Security governance can now be located precisely within the larger structure. It is the means by which an organization controls and directs its approach to security, and when it is done well it coordinates all of the organization's security activities and enables the flow of security information and security decisions throughout the organization. Structurally, security governance is a **vertical** concern that cuts across the other governances: it sits within IT governance, which sits within corporate governance, which — alongside business governance — sits within enterprise governance. The nesting looks as follows.



The reasons to care about security governance follow directly from this position. It provides a structured approach to managing and mitigating cybersecurity risks within the organization. It helps protect sensitive data, maintain regulatory compliance, and strengthen the trust and confidence of stakeholders. And by implementing effective security governance, an organization reduces both the likelihood and the impact of security incidents, thereby safeguarding its reputation and its business operations.

This defines the arc of the entire subject. The study of security governance will proceed through models for information security governance and the vertical nature of security; through cybersecurity best practices, guidelines, and frameworks and how to use them; through the assessment and management of risk, which entails understanding threats, vulnerabilities, and attacks, evaluating their impact, and finding proper countermeasures; through the modelling and understanding of threats; through the management of incidents; and finally through legislation, compliance, and insurance, closing on open research issues in security governance.

A Model for Information Security Governance

Recap: What Information Security Governance Is

Before assembling the full model, it is worth restating the object of study with precision. **Information Security Governance (ISG)** is the process of establishing and maintaining a framework, together with the supporting management structure and processes, that provides assurance of several things at

once: that information security strategies are aligned with and support the business objectives; that they are consistent with applicable laws and regulations through adherence to policies and internal controls; and that responsibility is properly assigned throughout the organization — all of this undertaken in an effort to manage risk. Said more plainly, ISG is the global effort a company makes to ensure the well-being of its electronic resources.

The Principle of Cost-Effectiveness

The first foundational principle on which any ISG framework must be built is that it has to be **cost-effective**. Security is expensive, and there must therefore be a deliberate balance between the cost of protecting electronic resources and the risk to which those resources are exposed. This balance has two failure modes, each equally to be avoided. **Overprotection** wastes money on defences whose cost exceeds the harm they prevent, generating unnecessary expense.

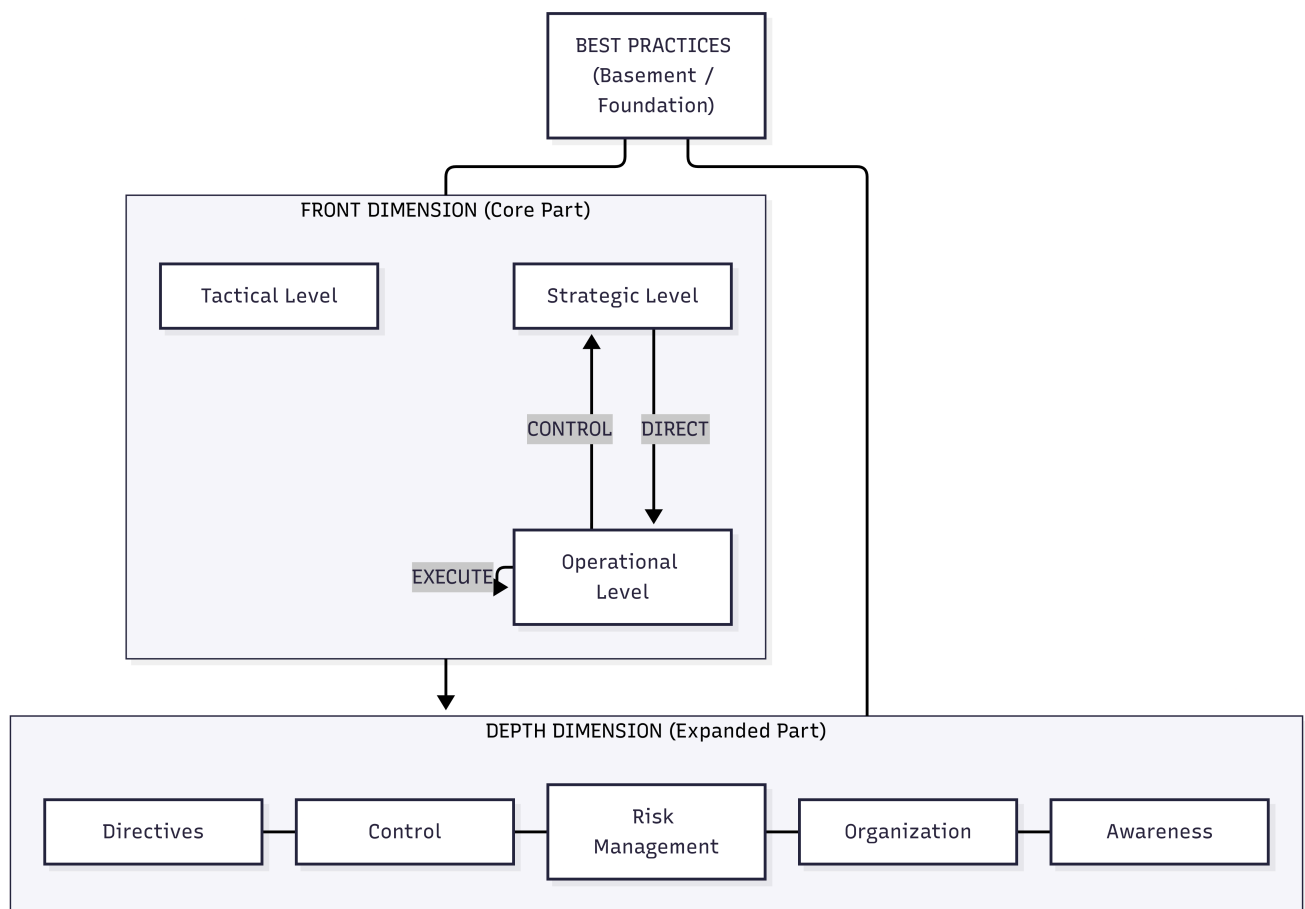
Underprotection leaves genuine exposures unaddressed, allowing risks to materialize and strike the company. Good governance lives in the narrow band between these two errors.

The practical force of this principle becomes visible the moment one imagines the two possible worlds. Suppose a risk assessment has been carried out and has produced a list of risks, each tagged with an associated security level. In an idealized world with no budget limit, one could simply march down the list and remediate every risk one by one until none remained. Real organizations do not live in that world: they operate under a **fixed budget** and must decide where that budget goes, starting from the most critical risks and working downward. A characteristic situation then arises in which most of the budget has been consumed fixing the critical problems, and a residual amount remains. At this juncture the decision must be made carefully, weighing the cost of fixing a given remaining risk against the cost that would be incurred if that risk actually materialized — neither overspending on marginal exposures nor abandoning issues that quietly matter. Even the act of *identifying* a risk depends on acquiring and analysing data with the right instruments; if the proper instruments are not used, important points may simply be missed, and the balance will be struck on incomplete information. For all these reasons, a good **IT risk management strategy** is mandatory as the precondition for a good ISG strategy, and good governance as a whole demands a strategy that weighs multiple aspects rather than fixating on the infrastructure alone.

The Von Solms Model: Overview

The model used to organize all of these elements was introduced by **R. Von Solms in 2006**. It can be pictured as a solid three-dimensional wedge whose purpose is to gather every element one must keep in mind and to arrange those elements in an interconnected structure. The wedge has three distinguishable parts, and understanding the model means understanding what each part contributes.

The **Front Dimension**, also called the **Core Part**, is the triangular face of the wedge. It is the implementation of the control loop already studied, spanning the three management layers of the pyramid. The **Depth Dimension**, also called the **Expanded Part**, is the set of five layers extending backward from that front face: **Directives, Control, Risk Management, Organization, and Awareness**. Finally, the **basement** on which the whole wedge rests is the **Best Practices** layer, the foundation from which everything else is constructed. Best practices are the documents that collect the common, accumulated knowledge of the field in terms of cybersecurity and management. The overall structure is shown below.



The Front Dimension (Core Part)

The Front Dimension represents the execution of processes and actions and the influence of the Direct and Control loop upon those processes. It rests on two core principles.

Core Principle 1 states that the model covers the three well-known levels of management — strategic, tactical, and operational. This principle answers the question of *why all three levels must be covered by the governance process*: every level possesses its own distinct view of the company, and no single level can see the whole. At the top, a handful of people take general decisions and, when the direct process begins, they possess only ideas about what to do; the directive documents they eventually write are therefore quite general. At the bottom, people are in direct contact with the system, laying their hands on machines and producing procedures, and their scope is extremely detailed and correspondingly restricted. Because each person's view is limited in this way, the intermediate tactical layer is indispensable: its whole function is to translate the general into the detailed on the way down, and, on the way up, to translate the detailed back into the general. This is why the processes must be able to flow *vertically* in both directions. On the control path, the operational level begins by collecting information of great precision — numbers of alerts, flows across different machines, and similar indicators — and this precise information is progressively correlated with the procedures and abstracted as it climbs, so that the movement upward is a movement from a very detailed view toward an increasingly summarized one.

Core Principle 2 states that across these three levels there are three very distinct *actions*, and that control at the bottom is emphatically not the same activity as control at the top. The rationale is easy to appreciate from the Board's perspective: the Board is not interested in learning that 321 virus attacks occurred last week, that 27 software patches were applied, and that 7 anti-virus updates took place — this is far too much detail to plan with. What the Board wants to know is whether the company's access to the Internet causes any *unmitigated* risks to the company. If there are none, the Board is content; if there are some, the Board wants to be told precisely which unmitigated risks these are. The action of control must therefore be qualitatively different at each altitude.

The Direct Part, Layer by Layer

The downward Direct process can be read as a matrix in which each management layer has a distinct meaning, a specific input, and a specific output, and in which the output of one layer becomes the input of the next.

At the **strategic level**, to direct means to **identify the assets, their relevance, and their required level of protection** — appropriate here because the strategic level alone possesses the overview of the whole company and can therefore say what must be protected and to what extent. Its **input** is the

context, split into internal and external factors. The internal factors concern the company's own world: its strategic vision, the role of IT, its competitiveness, its mission, its constraints, and its production processes. The external factors concern the surrounding world: legal and regulatory prescriptions and other external risks. Its **output** is a set of **Directives** indicating, at a high level, what the Board expects to be done as far as the protection of the company's information assets is concerned.

At the **tactical level**, the directives received from above are *expanded* into sets of relevant information security **policies, company standards, and procedures**. Here the macro-objective is analysed against the situation and translated into middle-level objectives. The **input** is the set of directives produced above, and the **output** is the collection of policies, procedures, and standards with which the company must comply — the way digital resources are managed, the way accounts are handled, and so on.

At the **operational level**, the inputs are expanded further into sets of **administrative guidelines and administrative procedures**, and the technical measures are physically implemented and managed. The **output** is the set of **operating procedures** specifying exactly how things must be done, and this output forms the very basis of execution on the lowest level.

The Control Part, Layer by Layer

The upward Control process is governed by a single, decisive maxim: **you can only manage what you can measure**. To control properly one must measure; to measure one must know in advance which information and data to collect. This *measurability* characteristic cannot be an afterthought — it must sit at the centre of all directives, policies, standards, and procedures produced during the Direct part of the model, so that the objects being directed are constructed to be measurable in the first place. The Control matrix mirrors the Direct matrix but runs in the opposite direction, from operational up to strategic.

At the **operational level**, to control means that **measurement data is extracted from a wide range of entities**, either automatically or manually. Concretely, this means deploying monitors — **agents** — into the environment to collect and extract data. These agents may live on the machines themselves or in the network, and their power depends on their observation range. Here a fundamental tension must be respected: **the need for monitoring must not compete with the needs of the business**. Observing everything by placing

agents everywhere is expensive and degrades the system's speed; when one interferes with the system to monitor it, one cannot do too much, or the system will suffer. The guiding rule is that the need for protection must exist and survive alongside the need of the business, without smothering it. The **input** at this level is the raw **measurements**, and the **output** is a set of **specialized reports** created on this level from the extracted operational data, which is then passed upward to the tactical level.

At the **tactical level**, control means **measurement and monitoring against the requirements of the relevant policies, procedures, and standards**. The tactical layer receives all the operational reports, aggregates them together, and attempts to identify existing threats, evaluating whether the policies in force are sufficient. Its **output** is a set of **tactical management reports** indicating the levels of compliance and conformance, which are then encapsulated and passed to the strategic level.

At the **strategic level**, control culminates in **Situational Awareness**. The **output** at this apex consists of **reports reflecting compliance and conformance to the relevant directives, including risk considerations** — the very snapshot the Board needs in order to decide whether to hold course or re-direct.

The Basement: Best Practices

Underneath both the Front and the Depth dimensions lies the layer of **best practices**, which sets the ground on which all operations are instantiated. Best practices are documents collecting the knowledge that people have acquired over the years in terms of security and management. The specific best practice one reaches for depends on the specific problem to be solved, and the required granularity depends on the management level being served.

The purpose of the whole ISG model, phrased memorably, is to help the organization in *"doing the right things right."* This slogan resolves into two questions that every **Information Security Manager (ISM)** must be able to answer. First: *how do I know what the right things are?* Second, supposing that is known: *how do I know I am doing them right?* The answer to both is: look to best practices. Formally, best practices — also called standards or guidelines — are a set of documents reporting the experiences and solutions arrived at by experts in information security management. They can be understood as the consensus of experts in the field, and they provide an internationally accepted framework usable

as a building block for ISG. Many of them exist, each focused on related but different aspects, including the **ISO 27000 family**, **COBIT**, the **NIST SP 800-* series**, the **CSC** (Critical Security Controls), and the **NIST CSF** (Cybersecurity Framework), among others.

ISO 27002

Among these best practices, **ISO 27002** deserves close attention because companies use it to set up their infrastructures from the policy point of view. It is an International Standard designed to be used by organizations that intend to do any of three things: to select controls within the process of implementing an Information Security Management System (ISMS) based on ISO/IEC 27001; to implement commonly accepted information security controls; or to develop their own information security management guidelines.

ISO 27002 is fundamentally a collection of **controls** — points that need to be verified. In its 2013 edition it contains **14 security control clauses**, which collectively hold a total of **35 main security categories** and **114 controls**. (These controls are general security controls and are not themselves objects of certification; they function as instructions rather than as a pass/fail certificate.) The structure is strictly hierarchical: each clause that defines security controls contains one or more main security categories, and each main category in turn contains two things — first, a **control objective** stating what needs to be achieved, and second, one or more **controls** that can be applied to achieve that objective.

The description of each individual control is itself standardized into a fixed structure of three parts. The first part is the **Control** proper, which defines the specific control statement needed to satisfy the control objective. The second part is the **Implementation Guidance**, a longer text that provides more detailed information to support the implementation of the control and the meeting of its objective; this guidance carries an explicit caveat, namely that it may not be entirely suitable or sufficient in every situation and may not fulfil an organization's specific control requirements. The third part is **Other Information**, which provides further considerations such as legal factors and references to other standards, and which is simply omitted when there is nothing further to say. In this way a control functions as a security checklist item that matches the requirements for certification, accompanied by a guideline explaining one possible way to implement something compliant with the check.

ISO 27001 and the Distinction Between the Two Standards

ISO 27001 is the companion International Standard that specifies the requirements for establishing, implementing, maintaining, and continually improving an ISMS within the context of the organization. It also includes requirements for the assessment and treatment of information security risks tailored to the organization's needs, and it is deliberately generic, intended to be applicable to all organizations regardless of type, size, or nature. Crucially, ISO 27001 is the standard that grants **certification**: it certifies that a system is compliant with its requirements, and it operates as a checklist of security checks that a company must satisfy to be formally certified.

The relationship between the two standards is best understood as a division of labour, and the difference between them is the difference between a requirement and a guideline. **ISO 27001** is very specific and strict; it spells out in detail what a company must comply with and must have in place in order to be formally certified. **ISO 27002**, by contrast, is a *guideline* document. It advises companies on what they should have in place as far as their information security management is concerned in order to follow best practice, guiding a company to structure its information security management according to the accumulated experience of other companies. It is deliberately rather high-level and does not drill down into very detailed specifics. The compact way to remember the pairing is that **27001 certifies and is strict, while 27002 guides and is advisory.**